信息安全测评与风险评估

7.4.1 工控系统架构认知

授课教师：张玉



目录

CONTENTS

01 案例导入——“震网病毒：摧毁核设施的代码”

02 学习目标

03 什么是工业控制系统（ICS）？

04 三大核心工控系统类型

案例导入——“震网病毒：摧毁核设施的代码”

2010年，伊朗核设施上千台离心机在监控“一切正常”时自毁。

震网（Stuxnet）：第一个专门摧毁实体设施的病毒，攻击对象是与互联网物理隔离的核设施。

病毒先感染外网电脑，经U盘“摆渡”进入与互联网隔离的内网，逐层渗透后驻留在控制层PLC，悄悄修改离心机转速，同时向监控层回传“一切正常”的假数据——操作员看着正常屏幕，上千台离心机却在异常运转中报废。

问题：

- 物理隔离都没能拦住的攻击，究竟钻了架构上的哪一道缝隙？

敲黑板：

工控安全关乎国计民生——电力、石油、交通、供水，任何环节出问题，都可能造成严重的社会后果。

维度	内容
攻击目标	伊朗纳坦兹核设施
攻击方式	攻击西门子S7-300/400系列PLC
攻击效果	修改离心机转速，导致物理损坏
隐蔽性	向监控系统回传伪造的正常数据
规模	感染全球超过20万个网络节点
历史地位	首个被确认的针对工业控制系统网络战武器

学习目标

通过本课学习，你将能够：

01 **理解：**工业控制系统（ICS）的基本概念、主要类型和核心组件

02 **掌握：**工业控制系统的五层架构模型

03 **理解：**工控系统与企业IT系统的根本区别

04 **识别：**工控系统的核心安全脆弱点

05 **为：**后续工控安全扩展要求测评学习奠定基础

什么是工业控制系统（ICS）？

1 GB/T 32919-2016 定义

工业控制系统（Industrial Control System，ICS）是一个通用术语，包括多种工业生产中使用的控制系统，包括数据采集与监视控制系统（Supervisory Control And Data Acquisition，SCADA）、分布式控制系统（Distributed Control System，DCS）和其他较小的控制系统，如可编程逻辑控制器（Programmable Logic Controller，PLC）。

2 通俗理解

- 工控系统 = 工业生产的**“大脑”**和**“神经系统”**
- 控制工业生产过程——从石油炼化到电力输送等。

行业	典型应用
电力	发电厂控制、电网调度
石油化工	炼油控制、管道监控
水处理	自来水厂、污水处理厂
交通	地铁信号控制、交通调度
制造业	生产线自动化控制
国防	武器装备控制

三大核心工控系统类型

记住三个缩写：SCADA、DCS、PLC——它们是工控系统的“三驾马车”。

SCADA

（监控和数据采集系统）

☑定位：上层监控调度软件体系

☑擅长：远距离、大范围的数据采集、监视、下发指令，一般不做复杂的底层闭环控制

典型场景：长距离管线、城市供水、油气管道、电网远动、多个站点集中监控。

☑特点：

- SCADA 本身通常不直接控制设备；控制是靠下面的 PLC/RTU 完成；
- 重点：收数据、画面展示、报警、历史记录、远程下发设定值；
- 可以对接很多不同品牌、不同地点的 PLC/RTU；
- 重点在“监视 + 采集”，不是成套控制硬件。

DCS

（分布式控制系统）

☑定位：成套的、一体化的大型控制系统

☑擅长：连续工艺、模拟量、闭环调节（温度、压力、液位、流量持续稳定控制）

典型场景：炼油、化工、电厂、制药、大型冶金。

☑特点：

- 控制分散在各个现场控制站，操作、显示集中在中控室；
- 天生重视冗余、安全、联锁，可靠性等级极高；
- 整套软硬件同厂商配套；
- DCS 里面的现场控制站，功能上很像 PLC，但架构是成套一体的。

PLC

（可编程逻辑控制器）

☑定位：现场独立控制单元（控制器硬件）

☑擅长：开关量、逻辑、顺序控制

典型场景：流水线、包装机、电梯、单台设备、泵站、风机、阀门启停。

☑特点：

- 单台 PLC 负责一小套设备；
- 编程灵活（梯形图等）；
- 可以单独运行，脱离上位机也能自主控制；
- 可以接入 DCS 或者 SCADA 系统。

– PLC（可编程逻辑控制器）——工控系统的“执行器”

PLC是工控系统中最核心、最常见、也是最容易成为攻击目标的设备。

PLC的组成及安全关注点

组成部分	功能	安全关注点
CPU	逻辑与数学运算	固件安全
存储器	存储程序与数据	程序篡改风险
输入/输出模块	接收/输出信号	I/O接口安全
通信接口	与其他设备通信	协议安全
电源	提供电力	供电安全



素材4：PLC基础知识快速参考卡.docx

PLC的工作原理：扫描周期

循环周期通常为10-100ms

1

输入采样

读取输入信号
（传感器/按钮等）

2

程序执行

按用户程序逻辑进行运算

3

输出刷新

运算结果输出
（电机/阀门等）

SCADA与DCS的区别

维度	SCADA	DCS
地理分布	广域（跨城市、跨省）	局域（工厂内部）
通信方式	无线、卫星、公网	有线工业以太网、现场总线
控制对象	分散的远程设备	集中的过程设备
实时性要求	**秒级~分钟级**	**毫秒级**
典型应用	电网调度、输油管道	化工厂、炼油厂
通信协议	IEC 60870-5、DNP3	Modbus TCP、PROFINET

工控系统的五层架构模型

依据IEC 62264-1标准，工控系统从上到下分为5个层级。



五层架构各层详解

素材1：工控系统架构认知记录表.do

层次	层级名称	核心设备/系统	核心功能	直观比喻
5	企业资源层	ERP系统	企业决策、供应链管理	类似于企业OA/财务系统
4	生产管理层	MES系统	生产调度、工艺管理	生产指挥中心
3	过程监控层	HMI、SCADA服务器	数据采集、人机交互	生产仪表盘
2	现场控制层	PLC、DCS控制器	逻辑控制、实时响应	生产大脑
1	现场设备层	传感器、执行器	感知物理世界、执行动作	生产手和眼

工控系统 vs 传统IT系统——根本区别

素材5：工控系统
vs IT系统快速对比-

理解工控系统的**“四个优先”**：实时优先、可靠优先、安全优先与可用性优先——这与IT系统完全不同。

维度	传统IT系统	工控系统
首要目标	机密性、完整性、可用性	可用性、完整性、机密性
实时性要求	秒级分钟级	毫秒级（PLC扫描周期10-100ms）
系统生命周期	3-5年	15-20年
补丁更新	频繁、可随时重启	极少、重启需停产
通信协议	TCP/IP、HTTP	Modbus、PROFINET、S7
物理隔离	通常连接互联网	传统上物理隔离，现正打破

工控系统面临的五大安全威胁

1. **定向攻击：**针对特定工控系统的网络攻击（典型案例：震网病毒 Stuxnet）
2. **勒索软件：**加密工控系统文件，勒索赎金（多家制造企业已遭遇）
3. **内部威胁：**内部人员误操作或恶意破坏（配置错误导致停产）
4. **协议漏洞：**工控协议设计时未考虑安全（Modbus无认证机制）
5. **供应链攻击：**通过第三方设备/软件植入后门（固件后门事件）

典型工控安全事件——“震网病毒”深度解析

震网病毒（Stuxnet）是世界上第一个被确认的“网络战武器”。

1 **初始渗透**
通过USB驱动器传播

2 **横向移动**
利用Windows零日漏洞

3 **目标识别**
识别西门子S7-300/400 PLC

4 **载荷注入**
修改PLC的代码块（DB/FC）

5 **破坏执行**
修改离心机转速参数

6 **痕迹清理**
向监控系统回传伪造数据

- 工控系统即使在**物理隔离环境**下也可能被攻击
- 攻击不仅影响IT系统，还会造成**物理破坏**
- 监控系统显示“正常”不代表真的正常——**可能已被欺骗**

等保2.0对工控安全的基本要求

GB/T 22239-2019 安全扩展要求 → 工业控制系统安全扩展要求

工控安全扩展要求的六个维度：

01 | 安全物理环境

室外控制设备物理防护

02 | 安全通信网络

网络架构（区域划分、隔离）

03 | 安全区域边界

访问控制、拨号/无线使用控制

04 | 安全计算环境

控制设备安全

05 | 安全建设管理

产品采购、外包软件开发

06 | 安全运维管理

工控环境运维管理

工控安全扩展要求——核心指标

本节重点掌握（第三级）：

维度	核心检查项	标准要求
访问控制	工控系统与企业其他系统之间区域隔离	应采用单向技术隔离手段
	工控系统内部安全域隔离	应根据业务特点划分不同安全域
	实时控制系统物理隔离	应使用独立网络设备组网
	穿越边界的通用服务限制	禁止E-Mail/Web/Telnet/FTP穿越边界
控制设备安全	控制设备身份鉴别/访问控制	应由上位机或管理手段实现
无线使用	无线通信加密认证	应提供唯一性标识和鉴别，且通信过程应采用加密技术保障数据机密性与完整性

实践任务1——工控系统架构认知（20分钟）

任务名称

工控系统五层架构认知

任务场景

MobLab实验平台“化工厂DCS”页

任务内容

① 识别架构图中的五层划分
② 标注各层的主要设备
③ 层间隔离与企业层连接方式
④ 填写《工控系统架构认知记录表》

时间安排：约20分钟



实践任务1——《工控系统架构认知记录表》

观察项	安全说明	记录内容
五层架构是否完整？	各层缺失将影响整体安全防护	
各层主要设备是什么？	识别设备类型是安全分析的前提	
层间隔离措施是什么？	等保要求区域间采取技术隔离	
企业层与工控层的连接方式	工控系统与企业其他系统之间应采用单向隔离	
是否存在可被利用的安全弱点？	识别脆弱性是风险评估的基础	

实践任务2——工控安全脆弱点分析（15分钟）

安全缺陷清单

1. 工控设备使用默认口令或弱口令
2. 工控系统与企业办公网络直接连接
3. 工控协议（如Modbus）无认证/加密机制
4. 工控设备补丁更新困难
5. 远程维护端口直接暴露在公网
6. 缺乏日志审计功能

任务名称

工控系统安全脆弱点分析

素材2：工控系统安全脆弱点分析表.(

任务场景

教师提供工控系统常见安全缺陷清单，学生分析

任务内容

1. 逐项分析安全风险
2. 判断是否符合等保要求
3. 提出初步改进建议

思政融入——工控安全关乎国家安全

国家安全

- 工业控制系统是“关键信息基础设施”的核心
- 电力、石油、交通、供水——任何一个出问题，都将影响国计民生
- 震网病毒告诉我们：网络攻击可以摧毁物理设备

自主可控

- 工控设备自主可控是国家战略
- 进口设备可能潜藏后门
- 等保2.0强调“产品采购符合国家规定”

使命担当

- 工控安全测评师是“国门卫士”
- 每一次测评都在守护工业“生命线”
- 做信息安全从业者，要有家国情怀

工控安全无小事，一处疏忽可能造成不可挽回的损失。

课堂小结：震网走过的那张架构图

知识点回顾

（5分钟）

01 ICS 概述

定义与应用；三大类型：SCADA / DCS / PLC

02 工控系统五层架构

L5(ERP) → L4(MES) → L3(HMI) → L2(核心) → L1(设备)

03 工控 vs IT系统

首要目标：可用性 > 完整性 > 机密性；实时性等差异

04 核心安全威胁

震网病毒(Stuxnet)、勒索软件、协议漏洞、内部威胁

05 等保2.0工控扩展

网络架构(单向隔离)、访问控制、控制设备安全

课后作业

必做	完成《工控系统架构认知记录表》，提交至学习通平台
必做	完成活动7.4.1在线测试（选择题+判断题，共15题）
选做	搜索资料，了解“震网病毒”的详细攻击过程，写一份200字心得
预习	预习7.4.2“工控安全配置核查”相关内容

下节课预告

7.4.2 工控安全配置核查

预告内容

- 工控安全扩展要求测评指标详解
- 工控系统安全配置核查方法
- 《工业控制系统安全测评记录表》填写

课前准备

- 复习GB/T 22239工控扩展要求
- 了解工控安全审计相关工具

感谢观看

